MỤC LỤC

DANH MỤC TỪ VIẾT TẮT 2
DANH MỤC BẢNG 3
DANH MỤC HÌNH 4
MỞ ĐẦU 5
CHƯƠNG 1. BẢO MẬT DỮ LIỆU TRONG CƠ SỞ DỮ LIỆU ĐÁM MÂY ... 7
1.1. Điện toán đám mây và cơ sở dữ liệu được quản lý 7
1.2. Mô hình trách nhiệm chung 7
1.3. Các mối đe dọa với cơ sở dữ liệu đám mây 8
1.4. Bảo vệ mạng và đường truyền 8
1.5. Xác thực và phân quyền 9
1.6. Che dữ liệu 9
1.7. Mã hóa khi lưu trữ, khi truyền và khi sử dụng 9
1.8. Quản lý khóa 10
1.9. Audit 11
1.10. So sánh ba nền tảng 11
CHƯƠNG 2. THIẾT KẾ BẢO MẬT HỆ THỐNG 12
2.1. Lựa chọn nền tảng và môi trường 12
2.2. Kịch bản và phân loại dữ liệu 12
2.3. Mô hình đe dọa 12
2.4. Kiến trúc hệ thống 13
2.5. Vai trò và đặc quyền 14
2.6. Ánh xạ mối đe dọa với biện pháp kiểm soát 14
2.7. Thiết kế mã hóa theo trường 15
CHƯƠNG 3. TRIỂN KHAI VÀ ĐÁNH GIÁ 16
3.1. Tổng quan triển khai 16
3.2. Bảo vệ đường truyền và mạng 16
3.3. Phạm vi mở của Data API 17
3.4. Kiểm soát truy cập theo vai trò 17
3.5. Row-Level Security 18
3.6. Che dữ liệu 19
3.7. Mã hóa phía client 20
3.8. Mã hóa khi lưu trữ 21
3.9. Ghi log audit 21
3.10. Hiệu năng 22
3.11. Đánh giá các biện pháp 23
KẾT LUẬN 24
TÀI LIỆU THAM KHẢO 25

DANH MỤC TỪ VIẾT TẮT

Từ viết tắt	Ý nghĩa
AAD	Additional Authenticated Data – Dữ liệu xác thực bổ sung
AES	Advanced Encryption Standard – Chuẩn mã hóa nâng cao
API	Application Programming Interface – Giao diện lập trình ứng dụng
CIDR	Classless Inter-Domain Routing – Định tuyến liên miền không phân lớp
DBA	Database Administrator – Quản trị viên cơ sở dữ liệu
DDM	Dynamic Data Masking – Che dữ liệu động
GCM	Galois/Counter Mode – Chế độ Galois/Counter
HMAC	Hash-based Message Authentication Code – Mã xác thực thông điệp dựa trên băm
IaaS	Infrastructure as a Service – Hạ tầng như một dịch vụ
IP	Internet Protocol – Giao thức Internet
KMS	Key Management Service – Dịch vụ quản lý khóa
PaaS	Platform as a Service – Nền tảng như một dịch vụ
RBAC	Role-Based Access Control – Kiểm soát truy cập theo vai trò
RDS	Relational Database Service – Dịch vụ cơ sở dữ liệu quan hệ của Amazon
REST	Representational State Transfer
RLS	Row-Level Security – Bảo mật mức dòng
SaaS	Software as a Service – Phần mềm như một dịch vụ
SQL	Structured Query Language – Ngôn ngữ truy vấn có cấu trúc
TDE	Transparent Data Encryption – Mã hóa dữ liệu trong suốt
TLS	Transport Layer Security – Bảo mật tầng giao vận

DANH MỤC BẢNG

Bảng 1. Thành viên và phân công nhiệm vụ..... 6
Bảng 2. Phân chia nhiệm vụ bảo mật với cơ sở dữ liệu được quản lý..... 7
Bảng 3. Các mối đe dọa chính với cơ sở dữ liệu đám mây 8
Bảng 4. Mã hóa theo trạng thái dữ liệu..... 10
Bảng 5. Tính năng bảo mật của ba nền tảng cơ sở dữ liệu đám mây 11
Bảng 6. Phân loại và bảo vệ dữ liệu..... 12
Bảng 7. Ma trận vai trò và đặc quyền 14
Bảng 8. Mối đe dọa, biện pháp kiểm soát và cách kiểm chứng..... 14
Bảng 9. Tóm tắt kết quả thực nghiệm..... 16
Bảng 10. Độ trễ truy vấn với cột thường và cột mã hóa (mili giây)..... 22
Bảng 11. Điều mỗi biện pháp ngăn được và không ngăn được..... 23

DANH MỤC HÌNH

Hình 1. Kiến trúc hệ thống và ranh giới tin cậy 13
Hình 2. Các lớp phòng thủ theo chiều sâu của thiết kế 14
Hình 3. Luồng mã hóa, lưu trữ và giải mã theo trường 15
Hình 4. Kết quả kiểm thử đường truyền và mạng 17
Hình 5. Kết quả kiểm thử Data API 17
Hình 6. Kết quả kiểm thử kiểm soát truy cập 18
Hình 7. Kết quả kiểm thử Row-Level Security 19
Hình 8. Kết quả kiểm thử che dữ liệu 20
Hình 9. Kết quả kiểm thử mã hóa phía client 20
Hình 10. Kiểm tra truy vết log audit và một số dòng mẫu 21

MỞ ĐẦU

Đưa cơ sở dữ liệu lên đám mây làm thay đổi câu hỏi ai có thể chạm tới dữ liệu. Với máy chủ riêng, tổ chức kiểm soát phần cứng, hệ điều hành và mạng. Với dịch vụ đám mây được quản lý, nhà cung cấp vận hành các lớp này, cơ sở dữ liệu có thể được truy cập qua Internet nếu không bị giới hạn, và những giao diện mới như API web tự sinh có thể xuất hiện bên cạnh cổng cơ sở dữ liệu truyền thống. Vì vậy, một thiết lập sai có thể làm lộ dữ liệu cho bất kỳ ai trên Internet chứ không chỉ cho những người trong một văn phòng.

Các nhà cung cấp đám mây giới thiệu nhiều cơ chế bảo vệ có sẵn, nhưng chúng chỉ giải quyết một phần vấn đề. Mô hình trách nhiệm chung [1], [2] vẫn để dữ liệu, quyền truy cập và cấu hình thuộc về khách hàng. Chẳng hạn, mã hóa khi lưu trữ không có tác dụng gì với người đăng nhập bằng thông tin hợp lệ. Do đó, nghiên cứu về bảo mật cơ sở dữ liệu đám mây cần đặt ra hai câu hỏi với mỗi cơ chế: cơ chế đó chặn được mối đe dọa nào, và còn để ngỏ mối đe dọa nào?

Mục tiêu. Báo cáo có ba mục tiêu: trình bày các mối đe dọa và cơ chế bảo mật chính của cơ sở dữ liệu đám mây; triển khai nhiều lớp cơ chế trên một cơ sở dữ liệu đám mây thật; và kiểm chứng bằng thực nghiệm xem mỗi cơ chế ngăn được gì, không ngăn được gì và tốn bao nhiêu chi phí hiệu năng.

Phạm vi. Phần triển khai dùng cơ sở dữ liệu PostgreSQL trên gói Free của Supabase, cho một phòng khám giả định với 200 hồ sơ bệnh nhân giả. Supabase được chọn vì có thể tạo dự án ngay mà không cần thẻ thanh toán. Azure SQL Database và Amazon RDS chỉ được tìm hiểu qua tài liệu và so sánh ở Chương 1, không được triển khai. Báo cáo không dùng dữ liệu cá nhân hay dữ liệu y tế thật. Hệ thống chỉ là bản minh họa học thuật, không phải sản phẩm sẵn sàng lưu hồ sơ bệnh nhân thật.

Phương pháp. Mỗi mối đe dọa được gắn với một cơ chế kiểm soát. Cơ chế đó được cấu hình bằng script có thể chạy lại, rồi một bài kiểm thử tự động thực hiện cả hành động hợp lệ lẫn hành động trái phép trên cơ sở dữ liệu đang chạy. Sau đó, cơ sở dữ liệu được xóa và dựng lại từ script. Toàn bộ hình ở Chương 3 lấy từ kết quả của lần chạy sạch này, được lưu trong thư mục `evidence` của dự án.

Cấu trúc. Chương 1 trình bày cơ sở lý thuyết và so sánh ba nền tảng. Chương 2 mô tả kịch bản, mô hình đe dọa và thiết kế. Chương 3 báo cáo quá trình triển

khai, kết quả và các hạn chế. Phần Kết luận tóm tắt các phát hiện và đề xuất hướng phát triển.

Thành viên và phân công. Dự án do nhóm ba thành viên thực hiện. Bảng 1 trình bày phần việc mà mỗi thành viên phụ trách.

Bảng 1. Thành viên và phân công nhiệm vụ

Thành viên	**Mã sinh viên**	**Nhiệm vụ**
Họ tên A	Mã SV	Đám mây và giám sát: môi trường Supabase; bảo vệ đường truyền, mạng và Data API; mã hóa khi lưu trữ; ghi log audit; đo hiệu năng (các mục 3.2, 3.3, 3.8, 3.9, 3.10)
Họ tên B	Mã SV	Bảo mật cơ sở dữ liệu: schema và dữ liệu giả; role, RLS, che dữ liệu và mã hóa phía client; kịch bản kiểm thử (Chương 2; các mục 3.4 đến 3.7)
Họ tên C	Mã SV	Lý thuyết và tổng hợp: Mở đầu, Chương 1, Kết luận và Tài liệu tham khảo; ghép và định dạng báo cáo; slide; kiểm tra chéo kết quả

CHƯƠNG 1. BẢO MẬT DỮ LIỆU TRONG CƠ SỞ DỮ LIỆU ĐÁM MÂY

1.1. Điện toán đám mây và cơ sở dữ liệu được quản lý

NIST định nghĩa điện toán đám mây là mô hình cho phép truy cập mạng thuận tiện, theo nhu cầu, tới một tập tài nguyên tính toán dùng chung có thể cấu hình, được cấp phát nhanh với công sức quản lý tối thiểu [3]. Định nghĩa này nêu năm đặc trưng thiết yếu: tự phục vụ theo nhu cầu, truy cập mạng rộng rãi, gộp tài nguyên, co giãn nhanh và dịch vụ được đo lường. Định nghĩa cũng mô tả ba mô hình dịch vụ là IaaS, PaaS và SaaS.

Dịch vụ cơ sở dữ liệu được quản lý gần với mô hình PaaS. Khách hàng nhận một điểm kết nối cơ sở dữ liệu sẵn sàng sử dụng, còn nhà cung cấp lo phần cứng, hệ điều hành, vá lỗi và vận hành cơ bản. Hai đặc trưng nêu trên liên quan trực tiếp đến bảo mật. Truy cập mạng rộng rãi nghĩa là cơ sở dữ liệu có thể được kết nối từ khắp nơi, nên mạng không còn là rào chắn tự nhiên. Gộp tài nguyên nghĩa là các khách hàng dùng chung hạ tầng vật lý và phụ thuộc vào khả năng cô lập của nhà vận hành. NIST SP 800-144 vì vậy khuyến nghị tổ chức tìm hiểu bảo mật trong môi trường của nhà cung cấp và vẫn chịu trách nhiệm về dữ liệu của mình khi dùng đám mây công cộng [4].

1.2. Mô hình trách nhiệm chung

Cả AWS và Microsoft đều mô tả bảo mật đám mây là sự phân chia nhiệm vụ [1], [2]. AWS tóm tắt thành bảo mật "của" đám mây, thuộc về nhà cung cấp, và bảo mật "trong" đám mây, thuộc về khách hàng. Bảng 2 áp dụng ý tưởng này cho cơ sở dữ liệu được quản lý. Điểm mấu chốt là các mục ở cột bên phải không thể giao lại cho người khác: nhà cung cấp không thể quyết định nhân viên nào của phòng khám được đọc hồ sơ nào.

Bảng 2. Phân chia nhiệm vụ bảo mật với cơ sở dữ liệu được quản lý

Nhà cung cấp	Khách hàng
Trung tâm dữ liệu, phần cứng và an ninh vật lý	Dữ liệu nào được lưu và mức độ nhạy cảm của dữ liệu
Hệ điều hành máy chủ và vận hành phần mềm cơ sở dữ liệu	Tài khoản, vai trò, đặc quyền và quy tắc mức dòng
Cô lập giữa các khách hàng	Danh sách mạng được phép và các giao diện được mở
Hạ tầng nền tảng, bao gồm mã hóa lưu trữ nếu có cung cấp	Bảo vệ khóa ứng dụng, bí mật và access token
Khả năng ghi log của nền tảng	Bật audit, xuất log và xem xét log

1.3. Các mối đe dọa với cơ sở dữ liệu đám mây

OWASP xếp kiểm soát truy cập bị phá vỡ ở vị trí thứ nhất và lỗi mật mã ở vị trí thứ hai trong Top 10 năm 2021 [5], [6]. Cả hai đều là vấn đề cốt lõi của cơ sở dữ liệu. Bảng 3 liệt kê các mối đe dọa được xét trong báo cáo. Danh sách này không đầy đủ: ví dụ, tấn công từ chối dịch vụ nằm ngoài phạm vi nghiên cứu.

Bảng 3. Các mối đe dọa chính với cơ sở dữ liệu đám mây

Mối đe dọa	**Mô tả**	**Tác động có thể có**
Mở mạng tự do	Điểm kết nối chấp nhận kết nối từ mọi địa chỉ	Dò mật khẩu, khai thác lỗ hổng
Nghe lén	Lưu lượng bị đọc hoặc sửa giữa client và server	Lộ thông tin đăng nhập và dữ liệu
Giao diện web bị mở	API tự sinh công khai các bảng dữ liệu	Dữ liệu bị đọc công khai
Đặc quyền quá mức	Người dùng hoặc ứng dụng có nhiều quyền hơn công việc cần	Thiệt hại lớn hơn khi có sai sót hoặc mất tài khoản
Truy cập ngang hàng	Người dùng hợp lệ đọc hồ sơ của người khác	Vi phạm quyền riêng tư trong nội bộ
Người nội bộ có đặc quyền	Quản trị viên hoặc nhân viên nhà cung cấp đọc trực tiếp dữ liệu	Lộ dữ liệu mà quy tắc truy cập thông thường không chặn được
Mất ổ đĩa hoặc bản sao lưu	Ổ đĩa hoặc bản sao lưu ra khỏi môi trường kiểm soát	Toàn bộ dữ liệu bị đọc ngoại tuyến
Hoạt động không bị phát hiện	Hành động không để lại bản ghi để xem xét	Sự cố bị phát hiện muộn hoặc không được phát hiện

1.4. Bảo vệ mạng và đường truyền

Các biện pháp mạng quyết định ai có quyền thử kết nối. Danh sách IP được phép giúp thu hẹp bề mặt tấn công, nhưng không xác thực người dùng và chỉ có tác dụng với các giao diện mà nó bao phủ. Ví dụ, trên Supabase, giới hạn mạng áp dụng cho kết nối Postgres trực tiếp và qua pooler, nhưng không áp dụng cho REST API, Storage hay Auth [7].

TLS bảo vệ lưu lượng khỏi bị đọc và sửa trên đường truyền. Có hai điểm cần chú ý. Thứ nhất, server phải bắt buộc dùng TLS: Supabase để SSL là tùy chọn với kết nối Postgres trực tiếp, trừ khi quản trị viên bật chế độ bắt buộc [8]. Thứ hai, chỉ mã hóa thì chưa chứng minh được server là ai. Để chống tấn công xen giữa

chủ động, client còn phải xác minh chứng chỉ của server, được biểu diễn trong client PostgreSQL bằng chế độ `verify-full` [8].

1.5. Xác thực và phân quyền

Xác thực xác định người dùng là ai, còn phân quyền quyết định người đó được làm gì. Nguyên tắc đặc quyền tối thiểu yêu cầu mỗi danh tính chỉ có các quyền mà công việc cần, và truy cập phải bị từ chối theo mặc định [5]. PostgreSQL thực hiện RBAC thông qua role và đặc quyền trên đối tượng được cấp bằng `GRANT` [9]. Đặc quyền có thể đặt theo bảng, thậm chí theo cột.

Đặc quyền trên bảng không phân biệt các dòng, nên PostgreSQL bổ sung RLS. Khi bật RLS trên một bảng, truy cập thông thường phải được một policy cho phép, và nếu không có policy thì mặc định là từ chối [10]. Mệnh đề `USING` chọn những dòng hiện có được nhìn thấy, còn `WITH CHECK` kiểm tra giá trị dòng mới. Các quy tắc bỏ qua rất quan trọng: superuser và role có thuộc tính `BYPASSRLS` luôn bỏ qua RLS, chủ sở hữu bảng cũng bỏ qua trừ khi đặt `FORCE ROW LEVEL SECURITY` [10]. Do đó, RLS kiểm soát người dùng thông thường chứ không kiểm soát quản trị viên. SQL Server và Azure SQL có cơ chế tương đương qua security policy với filter predicate và block predicate [11].

1.6. Che dữ liệu

Che dữ liệu (masking) ẩn một phần giá trị trong kết quả truy vấn, chẳng hạn chỉ hiện vài số cuối của số điện thoại. Đây là biện pháp tiện dụng, không phải mã hóa, vì giá trị gốc vẫn nguyên vẹn trong kho lưu trữ. Microsoft nêu rõ dynamic data masking không nhằm ngăn người dùng chạy các truy vấn dò tìm toàn diện, và cảnh báo người có quyền truy vấn tùy ý có thể suy ra giá trị thật: họ có thể lọc trên cột bị che với một khoảng giá trị đoán trước để tìm ra dòng khớp, dù kết quả hiển thị vẫn là số 0 [12]. Vì thế, che dữ liệu cần đi cùng kiểm soát truy cập và audit.

1.7. Mã hóa khi lưu trữ, khi truyền và khi sử dụng

Mã hóa bảo vệ dữ liệu ở ba trạng thái, và mỗi trạng thái ứng với một mối đe dọa khác nhau. Bảng 4 tóm tắt các trạng thái này.

Bảng 4. Mã hóa theo trạng thái dữ liệu

Trạng thái	Cơ chế điển hình	Điều không ngăn được
Khi lưu trữ	Mã hóa lưu trữ, TDE	Bất kỳ ai truy vấn qua cơ sở dữ liệu đang chạy, vì dữ liệu được giải mã cho họ
Khi truyền	TLS	Truy cập từ đầu cuối hợp lệ; tấn công vào client hoặc server
Trước cả server	Mã hóa phía client như Always Encrypted	Client hoặc khóa bị xâm phạm; đồng thời hạn chế truy vấn trên cột được mã hóa

TDE trên Azure SQL mã hóa cơ sở dữ liệu, bản sao lưu và log giao dịch ở mức trang. Mỗi trang được giải mã khi đọc vào bộ nhớ và mã hóa trước khi ghi xuống đĩa, và TDE được bật mặc định cho cơ sở dữ liệu mới [13]. Cùng nguồn này lưu ý tệp BACPAC xuất ra không được mã hóa, cho thấy sự bảo vệ có thể kết thúc ở một ranh giới mà người dùng không để ý. Tương tự, Amazon RDS dùng AES-256 cho lưu trữ, log, bản sao lưu tự động, bản sao đọc và snapshot, và chỉ có thể bật khi tạo instance [14].

Mã hóa phía client đi xa hơn bằng cách giữ khóa tách khỏi công cụ cơ sở dữ liệu. Always Encrypted tách người sở hữu dữ liệu khỏi người quản lý dữ liệu, kể cả người vận hành cơ sở dữ liệu trên đám mây, với cái giá là các thao tác trên cột mã hóa bị hạn chế [15]. Mã hóa tất định cho phép tra cứu bằng nhưng có thể lộ mẫu dữ liệu, còn mã hóa ngẫu nhiên mạnh hơn và không cho phép tìm kiếm. Thiết kế trong báo cáo này cũng gặp sự đánh đổi tương tự.

Phần triển khai dùng AES [16] ở chế độ GCM, một thuật toán được NIST khuyến nghị cho mã hóa có xác thực kèm dữ liệu liên kết [17]. Mã hóa có xác thực quan trọng vì vừa che nội dung vừa phát hiện được việc sửa đổi. Để tìm kiếm khớp chính xác trên giá trị đã mã hóa, có thể dùng hàm băm có khóa như HMAC [18] làm blind index: đầu vào giống nhau cho đầu ra giống nhau, còn người không có khóa thì không tính được.

1.8. Quản lý khóa

Mã hóa chuyển bài toán từ bảo vệ dữ liệu sang bảo vệ khóa. NIST SP 800-57 hướng dẫn toàn bộ vòng đời khóa, gồm tạo, lưu trữ, sử dụng, xoay vòng và hủy [19]. Các nền tảng đám mây cho phép chọn ai sở hữu khóa. Với khóa do nhà cung cấp quản lý, vận hành đơn giản nhưng vẫn phải tin tưởng nhà cung cấp. Với khóa do khách hàng quản lý, như Azure Key Vault cho TDE [13] hay customer managed key trong AWS KMS [14], khách hàng kiểm soát việc xoay vòng và

truy cập, và có thể làm dữ liệu không đọc được bằng cách thu hồi khóa. Quyền kiểm soát này đi kèm rủi ro riêng, vì mất khóa đồng nghĩa với mất khả năng truy cập dữ liệu.

1.9. Audit

Các biện pháp phòng ngừa có thể thất bại, nên hệ thống cần có bản ghi về những gì đã xảy ra. Azure SQL auditing ghi sự kiện vào storage account, Log Analytics workspace hoặc Event Hubs [20]. Amazon RDS có Database Activity Streams để giám sát gần thời gian thực [21]. Trên PostgreSQL, tiện ích mở rộng pgAudit tạo log audit chi tiết theo phiên và theo đối tượng qua cơ chế ghi log chuẩn [22]. Supabase chỉ cho phép cấu hình pgAudit ở mức role và hiển thị kết quả trong trình xem log [23]. Log chỉ có ích nếu được giữ đủ lâu và có người xem xét, nên thời gian lưu giữ phải là một phần của thiết kế.

1.10. So sánh ba nền tảng

Bảng 5 so sánh các tính năng liên quan đến nghiên cứu này, dựa trên tài liệu của nhà cung cấp. Azure SQL có nhiều tính năng dựng sẵn nhất, còn Supabase đòi hỏi tự xây dựng nhiều hơn. Kết quả ở Chương 3 không nói lên hành vi của các tính năng trên Azure và AWS.

Bảng 5. Tính năng bảo mật của ba nền tảng cơ sở dữ liệu đám mây

Tính năng	**Azure SQL Database**	**Amazon RDS for PostgreSQL**	**Supabase (PostgreSQL)**
Mã hóa khi lưu trữ	TDE, bật mặc định với cơ sở dữ liệu mới	AES-256, chọn khi tạo instance	AES-256 theo công bố của nhà cung cấp [24]
Khóa do khách hàng quản lý	Có, Azure Key Vault	Có, AWS KMS	Không thấy tùy chọn trong các trang đã xem
Đường truyền	TLS	SSL/TLS [25]	TLS; bắt buộc qua thiết lập
Mã hóa phía client	Always Encrypted có sẵn	Ứng dụng tự thực hiện	Ứng dụng tự thực hiện
Quy tắc mức dòng	Security policy	RLS của PostgreSQL	RLS của PostgreSQL
Che dữ liệu	DDM có sẵn	View hoặc tương tự	View hoặc tương tự
Audit	SQL auditing	pgAudit, Activity Streams	pgAudit ở mức role

CHƯƠNG 2. THIẾT KẾ BẢO MẬT HỆ THỐNG

2.1. Lựa chọn nền tảng và môi trường

Dự án ban đầu dự kiến dùng Azure SQL Database, nhưng việc đăng ký gói dành cho sinh viên không thành công. Nhóm chuyển sang Supabase vì đây là dịch vụ PostgreSQL thật trên Internet và không yêu cầu thẻ thanh toán khi đăng ký. Gói Free có các giới hạn rõ ràng: 500 MB cho mỗi dự án, giữ log một ngày, không có sao lưu tự động và bị tạm dừng sau một tuần không hoạt động [26]. Những giới hạn này ảnh hưởng đến thiết kế: log phải được xuất ngay, và toàn bộ cơ sở dữ liệu phải dựng lại được từ script.

Cơ sở dữ liệu chạy PostgreSQL 17.11 với pgAudit 17.1 tại region `ap-southeast-2`. Trên gói Free, kết nối trực tiếp chỉ hỗ trợ IPv6, nên client kết nối qua shared pooler ở session mode, cổng 5432, chế độ này cũng hỗ trợ role tự tạo [27]. Các script được viết bằng Node.js với driver `pg`.

2.2. Kịch bản và phân loại dữ liệu

Kịch bản là một phòng khám nhỏ giả định. Bác sĩ điều trị bệnh nhân của mình, lễ tân quản lý lịch hẹn và liên hệ bệnh nhân, quản trị viên duy trì hệ thống, còn kiểm toán viên kiểm tra việc tuân thủ quy tắc. Toàn bộ 200 hồ sơ bệnh nhân đều là dữ liệu giả: số điện thoại bắt đầu bằng `000`, số định danh bắt đầu bằng `999` để dễ nhận biết là giả, và email dùng tên miền dành riêng `example.com`. Bảng 6 cho thấy cách phân loại và bảo vệ từng loại dữ liệu.

Bảng 6. Phân loại và bảo vệ dữ liệu

Dữ liệu	**Độ nhạy cảm**	**Biện pháp bảo vệ**
Số định danh (CCCD)	Cao	AES-256-GCM phía client, blind index HMAC để tra cứu
Chẩn đoán	Cao	AES-256-GCM phía client
Điện thoại, email	Trung bình	Bị che với lễ tân, hiện với bác sĩ điều trị
Tên bệnh nhân	Trung bình	Kiểm soát truy cập và RLS; lễ tân được xem vì cần cho công việc
Lịch hẹn	Trung bình	RLS với bác sĩ, lễ tân được đọc

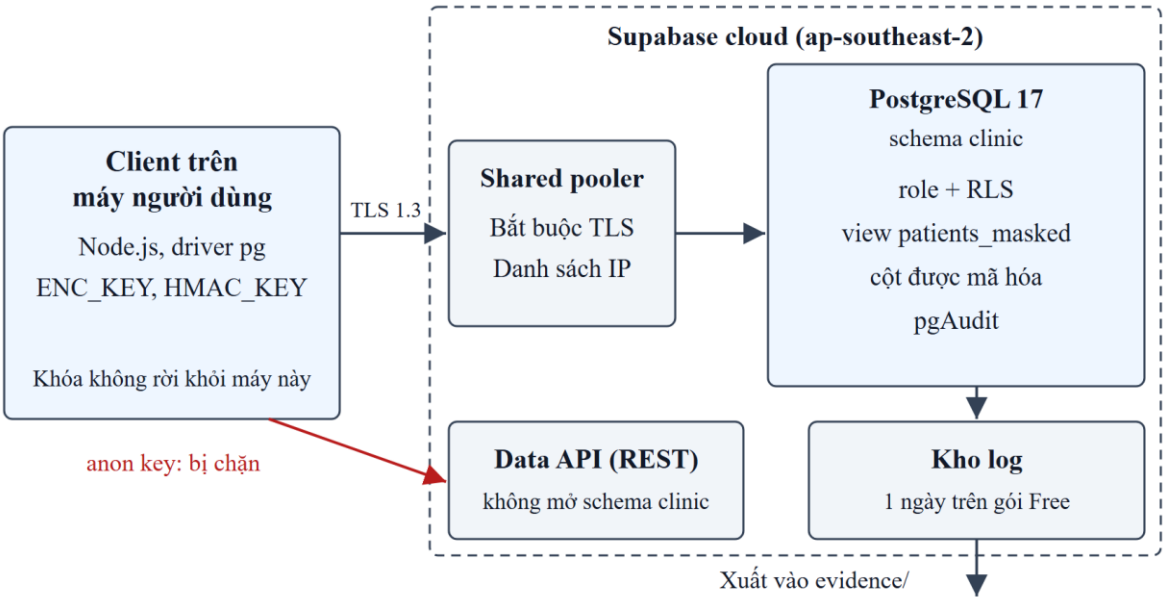
2.3. Mô hình đe dọa

Thiết kế giả định kẻ tấn công bên ngoài có thể tiếp cận các điểm kết nối công khai và có thể lấy được anon key công khai mà các dự án Supabase dùng trong ứng dụng client. Người nội bộ được giả định có tài khoản hợp lệ và có thể cố vượt

quá vai trò, còn quản trị viên hoặc nhân viên nhà cung cấp có thể đọc mọi thứ lưu trong cơ sở dữ liệu. Máy client giữ khóa mã hóa được xem là tin cậy. Kẻ tấn công kiểm soát được máy này, hoặc chính tài khoản Supabase, nằm ngoài mô hình, và không cơ chế nào trong thiết kế này chặn được họ.

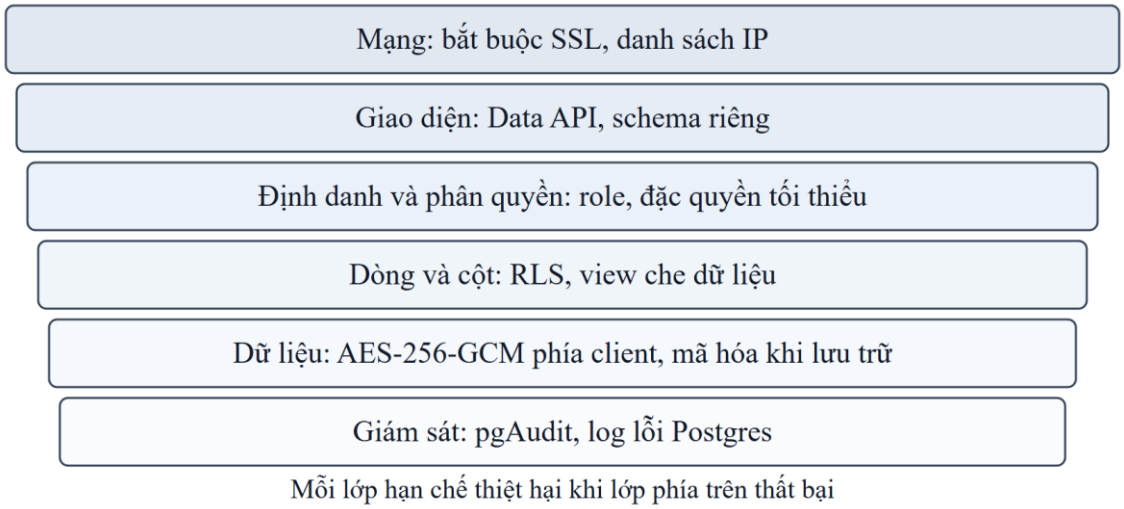
2.4. Kiến trúc hệ thống

Hình 1 trình bày kiến trúc. Client là thành phần duy nhất giữ khóa mã hóa. Mọi lưu lượng cơ sở dữ liệu đi qua shared pooler bằng TLS. Data API vẫn là một phần của nền tảng, nhưng schema `clinic` được chủ ý không mở cho API này. Log được lấy ra qua giao diện quản lý và lưu làm bằng chứng, vì gói Free xóa log sau một ngày.



Hình 1. Kiến trúc hệ thống và ranh giới tin cậy

Bảo mật được tổ chức theo chiều sâu để không phụ thuộc vào một biện pháp duy nhất. Hình 2 trình bày các lớp được dùng. Yêu cầu phải qua từng lớp ngoài trước khi tới dữ liệu, và ngay cả người tiếp cận được giá trị đã lưu cũng chỉ thấy bản mã ở các cột nhạy cảm nhất.



Hình 2. Các lớp phòng thủ theo chiều sâu của thiết kế

2.5. Vai trò và đặc quyền

Năm role đăng nhập đại diện cho những người trong kịch bản. Bảng 7 là ma trận truy cập được script triển khai. Có hai lựa chọn cần giải thích. Lễ tân không có đặc quyền trên bảng gốc `patients` và chỉ đọc qua view che dữ liệu. Quản trị viên đọc được mọi dòng vì công việc bảo trì cần điều đó, nhưng không sửa được gì và không giữ khóa mã hóa, nên các cột nhạy cảm nhất vẫn không đọc được với role này.

Bảng 7. Ma trận vai trò và đặc quyền

Role	Bảng patients	patients_masked	appointments	Giữ khóa
doctor_a, doctor_b	Dòng của mình: đọc; sửa chẩn đoán	Không	Dòng của mình: đọc	Có, trong client
receptionist	Bị từ chối	Đọc	Đọc	Không
db_admin	Mọi dòng: đọc	Không	Mọi dòng: đọc	Không
auditor	Bị từ chối	Không	Bị từ chối	Không

2.6. Ánh xạ mối đe dọa với biện pháp kiểm soát

Bảng 8 liên kết các mối đe dọa ở Bảng 3 với biện pháp được chọn và bài kiểm thử tương ứng. Biện pháp mà khách hàng không kiểm thử được sẽ được ghi rõ, để tài liệu không bị xem như bằng chứng.

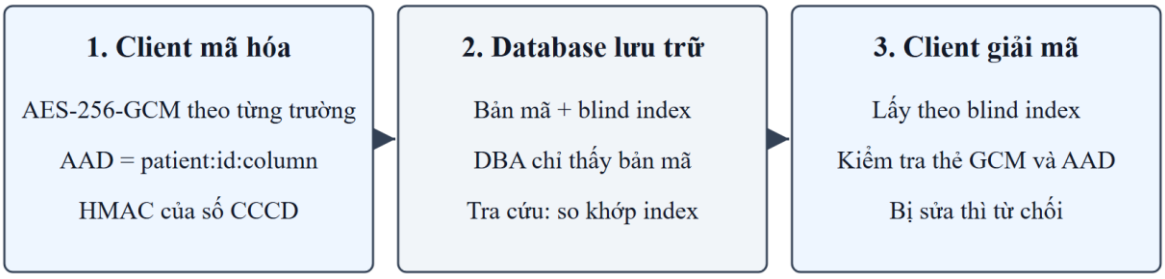
Bảng 8. Mối đe dọa, biện pháp kiểm soát và cách kiểm chứng

Mối đe dọa	Biện pháp	Kiểm chứng
Mở mạng tự do	Network Restrictions	Kiểm thử T1.4
Nghe lén	Bắt buộc SSL	Kiểm thử T1.1 đến T1.3

Mối đe dọa	Biện pháp	Kiểm chứng
Giao diện web bị mở	Schema riêng, không cấp quyền cho anon	Kiểm thử T2.1 và T2.2
Đặc quyền quá mức	RBAC, đặc quyền tối thiểu	Kiểm thử T3.1 đến T3.5
Truy cập ngang hàng	RLS	Kiểm thử T4.1 đến T4.6
Lộ dữ liệu không cần thiết cho nhân viên	View che dữ liệu	Kiểm thử T5.1 đến T5.3
Người nội bộ có đặc quyền	AES-256-GCM phía client	Kiểm thử T6.1 đến T6.4
Mất ổ đĩa hoặc bản sao lưu	Mã hóa khi lưu trữ của nhà cung cấp	Chỉ có công bố của nhà cung cấp; không kiểm thử được
Hoạt động không bị phát hiện	pgAudit và log lỗi Postgres	Xuất log và kiểm tra truy vết

2.7. Thiết kế mã hóa theo trường

Các trường nhạy cảm được client mã hóa trước khi gửi đi, như Hình 3. Mỗi giá trị dùng AES-256-GCM với nonce ngẫu nhiên 96 bit mới, và giá trị lưu gồm nonce, thẻ xác thực và bản mã. Dữ liệu xác thực bổ sung có dạng `patient:id:column`, gắn bản mã với đúng dòng và cột của nó. Nếu không có ràng buộc này, người nội bộ có thể chép chẩn đoán của bệnh nhân này sang bệnh nhân khác mà việc giải mã vẫn thành công. Số định danh còn có blind index HMAC-SHA-256 dùng khóa riêng, chỉ cho phép tra cứu chính xác.



Hình 3. Luồng mã hóa, lưu trữ và giải mã theo trường

CHƯƠNG 3. TRIỂN KHAI VÀ ĐÁNH GIÁ

3.1. Tổng quan triển khai

Phần triển khai gồm hai tệp SQL và một số script Node.js: `configure-cloud.js` đặt tùy chọn nền tảng, `setup-db.js` dựng lại schema và dữ liệu, `run-tests.js` chạy thực nghiệm, `export-logs.js` thu thập log và `benchmark.js` đo hiệu năng. Mật khẩu và khóa do script sinh ra và chỉ lưu trong tệp `.env` cục bộ, không đưa vào quản lý phiên bản. Kết quả được lọc để loại bỏ mã dự án, thông tin đăng nhập và địa chỉ IP trước khi ghi thành bằng chứng.

Script kiểm thử lần lượt kết nối tới cơ sở dữ liệu đang chạy bằng từng role, và một bài chỉ đạt khi hành vi quan sát được khớp với kỳ vọng. Trong lần chạy sạch cuối cùng, **24/24** bài kiểm thử đạt. Bảng 9 tóm tắt theo nhóm. Riêng T4.6 chỉ ghi nhận một sự kiện để phân tích hạn chế chứ không kiểm thử biện pháp nào. Bảy bài kiểm thử đơn vị riêng cho các hàm mã hóa cũng đều đạt.

Bảng 9. Tóm tắt kết quả thực nghiệm

Nhóm	Biện pháp	Số bài	Kết quả
T1	Đường truyền và mạng	4	Đạt toàn bộ
T2	Phạm vi mở của Data API	2	Đạt toàn bộ
T3	RBAC và đặc quyền tối thiểu	5	Đạt toàn bộ
T4	Row-Level Security	6	Đạt toàn bộ
T5	Che dữ liệu	3	Đạt toàn bộ
T6	Mã hóa phía client	4	Đạt toàn bộ

3.2. Bảo vệ đường truyền và mạng

Chế độ bắt buộc SSL được bật qua Management API. Như Hình 4, client đã thương lượng TLS 1.3 (T1.1), còn kết nối không dùng TLS bị từ chối với thông báo yêu cầu SSL (T1.2). Để kiểm thử danh sách IP, script tạm thay danh sách bằng `203.0.113.0/24`, dải địa chỉ dành riêng cho tài liệu, và lần kết nối sau đó bị từ chối vì địa chỉ client không nằm trong danh sách (T1.4). Thiết lập ban đầu được khôi phục tự động, và các bài kiểm thử sau xác nhận kết nối hoạt động trở lại.

```
[PASS] T1.1 Client connection uses TLS 1.2 or newer
    negotiated protocol: TLSv1.3
[PASS] T1.2 Unencrypted connection is rejected
    rejected: (ESSLREQUIRED) SSL connection is required for user: postgres
[PASS] T1.3 SSL enforcement reported as active
    API: {"currentConfig":{"database":true},"appliedSuccessfully":true}
[PASS] T1.4 IP outside the allowlist is blocked
    blocked: (EADDRNOTALLOWED) address not in tenant allow_list: <ip>
```

Hình 4. Kết quả kiểm thử đường truyền và mạng

Kết quả này có hai giới hạn. Phiên bản TLS đo được chỉ mô tả đoạn từ client đến pooler, còn đoạn từ pooler đến cơ sở dữ liệu không quan sát được từ bên ngoài. Ngoài ra, client kiểm thử không xác minh chứng chỉ server, nên các bài này chứng minh có mã hóa nhưng chưa chứng minh được danh tính server. Client trong sản phẩm thực tế nên dùng `verify-full` với chứng chỉ CA của nhà cung cấp [8].

3.3. Phạm vi mở của Data API

Supabase tự động công bố giao diện REST, và giới hạn mạng không bao phủ giao diện này [7], nên cần kiểm thử riêng. Các bảng của phòng khám được đặt trong schema riêng không mở qua Data API, và mọi đặc quyền của role `anon` đã bị thu hồi. Như Hình 5, yêu cầu dùng anon key tới schema này thất bại với HTTP 406 và lỗi `Invalid schema: clinic` (T2.1).

Một thí nghiệm đối chứng giúp kết quả trên có ý nghĩa. Script tạo một bảng tạm trong schema `public`, cấp quyền cho `anon` mà không bật RLS, rồi đọc được qua cùng API với HTTP 200 (T2.2), sau đó bảng được xóa. Điều này chứng minh đường truy cập vẫn hoạt động và việc từ chối trước đó là do cấu hình. Nó cũng cho thấy dữ liệu dễ bị công khai như thế nào: chỉ cần một lệnh `GRANT` trên bảng được mở mà không có RLS [28].

```
[PASS] T2.1 Anon key cannot read clinic.patients
    HTTP 406 {"code":"PGRST106","details":null,"hint":"Only the following schemas are expose
    d: public, graphql_public","message":"Invalid schema: clinic"}
[PASS] T2.2 Control: a public table granted to anon without RLS is readable
    HTTP 200 [{"note":"synthetic canary row"}]
```

Hình 5. Kết quả kiểm thử Data API

3.4. Kiểm soát truy cập theo vai trò

Mọi đặc quyền được thu hồi trước, rồi cấp theo từng role như Bảng 7. Hình 6 cho thấy lễ tân và kiểm toán viên bị từ chối trên bảng bệnh nhân, bác sĩ không xóa được và quản trị viên không sửa được, tất cả đều với mã lỗi PostgreSQL

42501. Trong bài T3.5, kiểm toán viên xác nhận các quyền này qua hàm catalog mà không đọc dữ liệu y tế nào.

```
[PASS] T3.1 Receptionist denied on base patient table
    role=receptionist
    sql=SELECT * FROM clinic.patients
    result: denied, 42501 permission denied for table patients
[PASS] T3.2 Doctor cannot delete patients
    role=doctor_a
    sql=DELETE FROM clinic.patients WHERE patient_id = 2
    result: denied, 42501 permission denied for table patients
[PASS] T3.3 DBA cannot modify clinical data
    role=db_admin
    sql=UPDATE clinic.patients SET phone = 'x'
    result: denied, 42501 permission denied for table patients
[PASS] T3.4 Auditor denied on clinical data
    role=auditor
    sql=SELECT * FROM clinic.patients
    result: denied, 42501 permission denied for table patients
```

Hình 6. Kết quả kiểm thử kiểm soát truy cập

3.5. Row-Level Security

RLS được bật và áp dụng bắt buộc trên hai bảng `patients` và `appointments`. Policy của bác sĩ so sánh mỗi dòng với hồ sơ bác sĩ của role hiện tại:

```
CREATE POLICY doctor_own_patients ON clinic.patients
  FOR SELECT TO doctor_a, doctor_b
  USING (doctor_id = (SELECT doctor_id FROM clinic.doctors WHERE db_role =
current_user));
```

Như Hình 7, cùng một truy vấn trả về 100 dòng chỉ của bác sĩ 1 cho `doctor_a` và 100 dòng chỉ của bác sĩ 2 cho `doctor_b`. Đọc trực tiếp bệnh nhân của bác sĩ kia không trả về dòng nào, và lệnh sửa bệnh nhân đó không tác động dòng nào. Cả hai trường hợp đều không báo lỗi, đúng với hành vi đã được mô tả của bộ lọc `USING` [10]: người không được phép thậm chí không biết được hồ sơ có tồn tại hay không.

```
[PASS] T4.1 Doctor A sees only own 100 patients
    role=doctor_a
    sql=SELECT count(*)::int AS visible, min(doctor_id) AS min_doc, max(doctor_id) AS max_do
    c FROM clinic.patients
    result: allowed, 1 rows, sample=[{"visible":100,"min_doc":1,"max_doc":1}]
[PASS] T4.2 Doctor B sees only own 100 patients
    role=doctor_b
    sql=SELECT count(*)::int AS visible, min(doctor_id) AS min_doc, max(doctor_id) AS max_do
    c FROM clinic.patients
    result: allowed, 1 rows, sample=[{"visible":100,"min_doc":2,"max_doc":2}]
[PASS] T4.3 Doctor A cannot read a patient of doctor B
    role=doctor_a
    sql=SELECT patient_id FROM clinic.patients WHERE patient_id = 1
    result: allowed, 0 rows, sample=[]
[PASS] T4.4 Doctor A update on a patient of doctor B affects 0 rows
    role=doctor_a
    sql=UPDATE clinic.patients SET diagnosis_enc = 'tampered' WHERE patient_id = 1
    result: allowed, 0 rows, sample=[]
```

Hình 7. Kết quả kiểm thử Row-Level Security

Bài T4.6 ghi nhận role nền tảng `postgres` có `rolbypassrls = true`. Vì vậy, RLS không bảo vệ được trước người giữ mật khẩu của role này. Đây là lý do RLS không được xem là đủ cho các cột nhạy cảm nhất.

3.6. Che dữ liệu

PostgreSQL không có cơ chế tương đương DDM dựng sẵn, nên việc che dữ liệu được thực hiện bằng view:

```
CREATE VIEW clinic.patients_masked AS
SELECT patient_id,
       full_name,
       '*******' || right(phone, 3)                                  AS phone,
       left(email, 1) || '***@' || split_part(email, '@', 2)         AS email,
       doctor_id
FROM clinic.patients;
```

Lễ tân chỉ có đặc quyền trên view này. Như Hình 8, điện thoại và email đều bị che (T5.1), còn bác sĩ vẫn thấy số thật của bệnh nhân mình (T5.3). Bài T5.2 thử cách suy đoán đã được mô tả với DDM [12]. Lọc theo tiền tố thật `000` của số điện thoại không trả về dòng nào, vì điều kiện được áp dụng trên kết quả đã che chứ không phải trên giá trị đang lưu.

```
[PASS] T5.1 Receptionist sees masked phone and email
    role=receptionist
    sql=SELECT * FROM clinic.patients_masked ORDER BY patient_id LIMIT 3
    result: allowed, 3 rows, sample=[{"patient_id":1,"full_name":"Nguyen Hai Giang","phone":
    "*******181","email":"p***@example.com","doctor_id":2},{"patient_id":2,"full_name":"Nguy
    en Duc Chi","phone":"*******941","email":"p***@example.com","doctor_id":1},{"patient_id"
    :3,"full_name":"Nguyen Hai Trang","phone":"*******743","email":"p***@example.com","docto
    r_id":2}]
[PASS] T5.2 Filtering on the masked column does not reveal the real value
    role=receptionist
    sql=SELECT patient_id FROM clinic.patients_masked WHERE phone LIKE '000%'
    result: allowed, 0 rows, sample=[]
[PASS] T5.3 Doctor sees the real phone of an own patient
    role=doctor_a
    sql=SELECT patient_id, phone FROM clinic.patients ORDER BY patient_id LIMIT 1
    result: allowed, 1 rows, sample=[{"patient_id":2,"phone":"0007256941"}]
```

Hình 8. Kết quả kiểm thử che dữ liệu

Không nên đánh giá quá cao kết quả này. Đây chỉ là một lần thử lọc, chưa phải phân tích đầy đủ về tấn công suy đoán. Thiết kế cũng phụ thuộc hoàn toàn vào việc từ chối truy cập bảng gốc, vì chỉ một lệnh `GRANT` nhầm là mất tác dụng. Hơn nữa, view chạy với quyền của chủ sở hữu nên RLS không giới hạn lễ tân, và lễ tân thấy được mọi bệnh nhân, đúng như vai trò này yêu cầu.

3.7. Mã hóa phía client

Hình 9 cho thấy những gì quản trị viên nhìn thấy: số định danh và chẩn đoán chỉ là bản mã Base64, dù role này đọc được mọi dòng (T6.1). Client có khóa khôi phục được giá trị (T6.2). Đổi một bit làm việc giải mã thất bại (T6.3), và đọc bản mã như thể nó thuộc về bệnh nhân khác cũng vậy (T6.4). Hai bài này cho thấy thiết kế đảm bảo cả tính toàn vẹn lẫn tính bí mật, vì lỗi được phát hiện ở client ngay cả khi kẻ tấn công kiểm soát toàn bộ dữ liệu lưu trữ.

```
[PASS] T6.1 DBA reads only ciphertext of sensitive columns
    role=db_admin
    sql=SELECT patient_id, national_id_enc, diagnosis_enc FROM clinic.patients WHERE patient
    _id = 2
    result: allowed, 1 rows, sample=[{"patient_id":2,"national_id_enc":"HBfGHIaxtrDFIZ2aG/aP
    2+aDxmJCsD/I9H+G9Defh6ghNzCEc6I43A==","diagnosis_enc":"MSZdgN3KXWVOZ3o0qy8TKPDBgZ0oAUH8c
    3SKkkudbmqWbXW4SoZwY15lBA=="}]
[PASS] T6.2 Client holding the key recovers the plaintext
    patient 2 diagnosis decrypted: Type 2 diabetes; national id format valid: true
[PASS] T6.3 Modified ciphertext is detected
    decryption refused: Unsupported state or unable to authenticate data
[PASS] T6.4 Ciphertext copied to another row is detected
    decryption refused: Unsupported state or unable to authenticate data
```

Hình 9. Kết quả kiểm thử mã hóa phía client

Các giới hạn là đáng kể. Cơ sở dữ liệu không thể sắp xếp, lọc theo khoảng hay tìm kiếm bên trong cột mã hóa. Blind index làm lộ những bệnh nhân có cùng

giá trị số định danh và chỉ hỗ trợ khớp chính xác. Trong bản minh họa này, mọi bác sĩ dùng chung một khóa lưu trong tệp cục bộ và không có xoay vòng, nên mất tệp đồng nghĩa với lộ mọi hồ sơ. Hệ thống thật nên giữ khóa trong KMS, theo vòng đời được mô tả ở NIST SP 800-57 [19].

3.8. Mã hóa khi lưu trữ

Supabase công bố toàn bộ dữ liệu khách hàng được mã hóa khi lưu trữ bằng AES-256 [24]. Khách hàng của dịch vụ được quản lý không có quyền tiếp cận ổ đĩa bên dưới và không có truy vấn nào chứng minh được tính chất này. Vì vậy, biện pháp này **chưa được kiểm chứng** trong dự án, và báo cáo chỉ ghi nhận đây là công bố của nhà cung cấp. Bản thân điều này là hệ quả thực tế của trách nhiệm chung: một số biện pháp chỉ có thể chấp nhận dựa trên sự tin tưởng hoặc báo cáo kiểm toán độc lập. Mã hóa phía client giảm bớt sự phụ thuộc này với hai cột được bảo vệ, nhưng không áp dụng cho tên, số điện thoại và email.

3.9. Ghi log audit

pgAudit được bật cho từng role minh họa với các lớp `read, write, ddl, role`. Sau khi kiểm thử, log được xuất qua Management API. Hình 10 cho thấy kết quả kiểm tra truy vết: mọi hành động trái phép đã thử và mọi lần đọc nhạy cảm được lấy mẫu đều được tìm thấy với đúng tên role. Bản xuất bao gồm hai lần chạy đầy đủ, với 20 dòng pgAudit và 8 dòng từ chối quyền, tức 10 và 4 dòng cho mỗi lần chạy.

```
20 pgaudit entries, 8 permission-denied entries

Traceability
FOUND    denied  receptionist  SELECT * FROM clinic.patients
FOUND    denied  doctor_a      DELETE FROM clinic.patients
FOUND    denied  db_admin      UPDATE clinic.patients
FOUND    denied  auditor       SELECT * FROM clinic.patients
FOUND    audit   doctor_a      UPDATE clinic.patients SET diagnosis_enc = 'tampered'
FOUND    audit   receptionist  clinic.patients_masked
FOUND    audit   db_admin      national_id_enc

Entries
2026-11-07 06:33:42.200000000  user=receptionist  ERROR  42501
    permission denied for table patients
    query: SELECT * FROM clinic.patients
2026-11-07 06:33:44.158000000  user=doctor_a  ERROR  42501
    permission denied for table patients
    query: DELETE FROM clinic.patients WHERE patient_id = 2
```

Hình 10. Kiểm tra truy vết log audit và một số dòng mẫu

Thực nghiệm đưa ra một phát hiện hữu ích. Các lệnh bị từ chối xuất hiện trong log lỗi của Postgres nhưng không thành dòng pgAudit, vì mỗi lần chạy có đúng 10 dòng pgAudit cho 10 lệnh thành công. Quy trình audit chỉ đọc các dòng `AUDIT:` sẽ bỏ sót đúng những hành vi cần thấy nhất, nên thiết kế audit phải dùng cả hai nguồn. Ngoài ra còn các giới hạn khác: role `postgres` không được cấu hình audit trong bản minh họa này, tham số của lệnh không được ghi lại, và log chỉ tồn tại một ngày trên gói này nếu không được xuất ra.

3.10. Hiệu năng

Bài đo so sánh cột thường và cột mã hóa trên hai bảng 200 dòng, trong cùng một kết nối. Mỗi thao tác chạy 100 lần sau 10 lần khởi động, các thao tác thường và mã hóa được xen kẽ để biến động mạng ảnh hưởng đều cho cả hai. Chi phí phát sinh được tính từ thời gian trung vị:

$$Chi\ phí\ phát\ sinh\ = \frac{t_{enc}\ -\ t_{plain}}{t_{plain}} \times\ 100\%$$

Bảng 10. Độ trễ truy vấn với cột thường và cột mã hóa (mili giây)

Thao tác	Trung vị thường	Trung vị mã hóa	p95 thường	p95 mã hóa
Tra cứu theo số định danh	236,86	236,88	237,71	237,62
Đọc 200 dòng	237,54	242,07	238,10	479,11
Chèn 1 dòng rồi xóa	475,43	475,71	476,41	476,77

Theo Bảng 10, chi phí phát sinh trung vị là 0,01% khi tra cứu, 1,9% khi đọc 200 dòng và 0,06% khi chèn. Các số liệu này chủ yếu do mạng quyết định. Một truy vấn đơn mất khoảng 237 ms, còn bài chèn mất khoảng gấp đôi vì thực hiện hai lệnh. Mã hóa và giải mã cục bộ chỉ mất 0,0187 ms cho mỗi giá trị. Điều này giải thích vì sao thao tác đọc nhiều dòng, phải giải mã 400 giá trị, là trường hợp duy nhất có khác biệt rõ.

Giá trị p95 khi đọc dòng mã hóa tăng lên 479,11 ms, tương đương thêm khoảng một lượt mạng khứ hồi. Kết quả mã hóa lớn hơn có thể là nguyên nhân, nhưng điều này chưa được điều tra, nên số liệu chỉ được báo cáo như đã quan sát. Bài đo dùng một client, một bảng nhỏ và dịch vụ dùng chung của gói Free ở region xa. Kết quả cho thấy chi phí mã hóa nhỏ trong điều kiện này, nhưng không nên xem là dự báo cho tải sản xuất hay máy chủ ở gần client.

3.11. Đánh giá các biện pháp

Bảng 11 tổng hợp các kết quả và là phát hiện chính của báo cáo. Không biện pháp nào bao phủ mọi mối đe dọa, và mỗi biện pháp đều có một điểm mà biện pháp khác phải tiếp nhận.

Bảng 11. Điều mỗi biện pháp ngăn được và không ngăn được

Biện pháp	**Ngăn được**	**Không ngăn được**
Bắt buộc SSL	Kết nối không mã hóa	Giả mạo server nếu client không xác minh chứng chỉ
Danh sách IP	Kết nối cơ sở dữ liệu từ địa chỉ khác	REST API; kẻ tấn công trong mạng được phép
Schema riêng	Truy cập qua Data API	Kết nối cơ sở dữ liệu trực tiếp với thông tin hợp lệ
RBAC	Hành động vượt quá vai trò	Lạm dụng các quyền hợp lệ của vai trò
RLS	Đọc và sửa dòng của bác sĩ khác	Role có `BYPASSRLS`, như `postgres`
View che dữ liệu	Lộ thông tin vô ý cho nhân viên	Người được cấp quyền trên bảng gốc; số cuối và tên vẫn hiện
Mã hóa phía client	Quản trị viên và nền tảng đọc hoặc sửa mà không bị phát hiện	Client hoặc khóa bị xâm phạm; tìm kiếm và sắp xếp trên cột
Mã hóa khi lưu trữ	Đọc ngoại tuyến ổ đĩa (theo công bố của nhà cung cấp)	Mọi truy cập qua cơ sở dữ liệu đang chạy
pgAudit và log lỗi	Hoạt động không bị phát hiện, nếu log được xem xét	Bản thân hành động; log chỉ ghi lại chứ không chặn

KẾT LUẬN

Dự án đã nghiên cứu các mối đe dọa với cơ sở dữ liệu đám mây và triển khai nhiều lớp biện pháp trên một dịch vụ PostgreSQL thật, với kịch bản phòng khám giả định và dữ liệu giả. Các biện pháp về mạng và đường truyền, phạm vi mở của API, RBAC, RLS, che dữ liệu bằng view, mã hóa phía client và ghi log audit đều được cấu hình bằng script có thể chạy lại. Trong lần chạy cuối sau khi dựng lại từ đầu, 24/24 bài kiểm thử tự động đạt, và mọi hành động trái phép đều được truy vết về đúng role trong log.

Có ba bài học chính. Thứ nhất, phần trách nhiệm của khách hàng rất lớn: các trường hợp lộ dữ liệu được minh họa trong nghiên cứu, như một bảng bị công khai qua REST API chỉ với một lệnh `GRANT`, đến từ cấu hình chứ không phải lỗi của nhà cung cấp. Thứ hai, mỗi biện pháp đều có giới hạn cụ thể: RLS không ràng buộc quản trị viên nền tảng, danh sách IP không bao phủ REST API, và mã hóa khi lưu trữ không chặn được đăng nhập hợp lệ. Bảo mật đến từ sự kết hợp các lớp, và Bảng 11 cho thấy lớp nào lấp khoảng trống nào. Thứ ba, kiểm thử có thể làm rõ những điều tài liệu chưa nêu bật, như việc lệnh bị từ chối xuất hiện trong log lỗi chứ không có trong pgAudit.

Mã hóa phía client là biện pháp mạnh nhất trước người nội bộ có đặc quyền, và chi phí trung vị đo được không quá 1,9% trong điều kiện này, khi độ trễ mạng chiếm phần lớn. Chi phí thật của nó nằm ở chức năng và quản lý khóa chứ không phải tốc độ.

Hạn chế. Chỉ một nền tảng được triển khai, nên phần so sánh với Azure và AWS dựa trên tài liệu. Mã hóa khi lưu trữ chưa được kiểm chứng. Client chưa xác minh chứng chỉ server. Khóa lưu trong tệp cục bộ, không có xoay vòng, và cấu hình audit chưa bao gồm role `postgres`. Bài đo hiệu năng còn nhỏ và dùng server ở xa. Bài thử suy đoán trên view che dữ liệu mới chỉ có một lần thử.

Hướng phát triển. Các bước hữu ích nhất tiếp theo là xác minh chứng chỉ server bằng `verify-full`, chuyển khóa sang KMS với xoay vòng và khóa riêng cho từng bác sĩ, chuyển log tới kho bên ngoài mà quản trị viên không sửa được, và lặp lại thực nghiệm trên Azure SQL để so sánh trực tiếp Always Encrypted, DDM và TDE dựng sẵn với các cơ chế tự xây dựng ở đây.

TÀI LIỆU THAM KHẢO

[1] Amazon Web Services, "Shared Responsibility Model", https://aws.amazon.com/compliance/shared-responsibility-model/, truy cập ngày 07/11/2026.

[2] Microsoft, "Shared responsibility in the cloud", https://learn.microsoft.com/en-us/azure/security/fundamentals/shared-responsibility, truy cập ngày 07/11/2026.

[3] P. Mell and T. Grance, "The NIST Definition of Cloud Computing", NIST SP 800-145, NIST, 2011.

[4] W. Jansen and T. Grance, "Guidelines on Security and Privacy in Public Cloud Computing", NIST SP 800-144, NIST, 2011.

[5] OWASP, "A01:2021 – Broken Access Control", https://top10.owasp.org/2021/A01_2021-Broken_Access_Control/, truy cập ngày 07/11/2026.

[6] OWASP, "A02:2021 – Cryptographic Failures", https://top10.owasp.org/2021/A02_2021-Cryptographic_Failures/, truy cập ngày 07/11/2026.

[7] Supabase, "Network Restrictions", https://supabase.com/docs/guides/platform/network-restrictions, truy cập ngày 07/11/2026.

[8] Supabase, "Postgres SSL Enforcement", https://supabase.com/docs/guides/platform/ssl-enforcement, truy cập ngày 07/11/2026.

[9] PostgreSQL Global Development Group, "Privileges", https://www.postgresql.org/docs/current/ddl-priv.html, truy cập ngày 07/11/2026.

[10] PostgreSQL Global Development Group, "Row Security Policies", https://www.postgresql.org/docs/current/ddl-rowsecurity.html, truy cập ngày 07/11/2026.

[11] Microsoft, "Row-level security", https://learn.microsoft.com/en-us/sql/relational-databases/security/row-level-security, truy cập ngày 07/11/2026.

[12] Microsoft, "Dynamic data masking", https://learn.microsoft.com/en-us/sql/relational-databases/security/dynamic-data-masking, truy cập ngày 07/11/2026.

[13] Microsoft, "Transparent data encryption – Azure SQL Database and Azure SQL Managed Instance", https://learn.microsoft.com/en-us/azure/azure-

sql/database/transparent-data-encryption-tde-overview, truy cập ngày 07/11/2026.

[14] Amazon Web Services, "Encrypting Amazon RDS resources", https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/Overview.Encryption.html, truy cập ngày 07/11/2026.

[15] Microsoft, "Always Encrypted", https://learn.microsoft.com/en-us/sql/relational-databases/security/encryption/always-encrypted-database-engine, truy cập ngày 07/11/2026.

[16] NIST, "Advanced Encryption Standard (AES)", FIPS 197, 2001, updated 2023.

[17] M. Dworkin, "Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC", NIST SP 800-38D, NIST, 2007.

[18] NIST, "The Keyed-Hash Message Authentication Code (HMAC)", FIPS 198-1, 2008.

[19] E. Barker, "Recommendation for Key Management: Part 1 – General", NIST SP 800-57 Part 1 Rev. 5, NIST, 2020.

[20] Microsoft, "Auditing for Azure SQL Database and Azure Synapse Analytics", https://learn.microsoft.com/en-us/azure/azure-sql/database/auditing-overview, truy cập ngày 07/11/2026.

[21] Amazon Web Services, "Monitoring Amazon RDS with Database Activity Streams", https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/DBActivityStreams.html, truy cập ngày 07/11/2026.

[22] pgAudit project, "PostgreSQL Audit Extension", https://www.pgaudit.org/, truy cập ngày 07/11/2026.

[23] Supabase, "PGAudit: Postgres Auditing", https://supabase.com/docs/guides/database/extensions/pgaudit, truy cập ngày 07/11/2026.

[24] Supabase, "Security at Supabase", https://supabase.com/security, truy cập ngày 07/11/2026.

[25] Amazon Web Services, "Securing connections to RDS for PostgreSQL with SSL/TLS", https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/PostgreSQL.Concepts.General.SSL.html, truy cập ngày 07/11/2026.

[26] Supabase, "Pricing", https://supabase.com/pricing, truy cập ngày 07/11/2026.

[27] Supabase, "Connect to your database", https://supabase.com/docs/guides/database/connecting-to-postgres, truy cập ngày 07/11/2026.

[28] Supabase, "Securing your API", https://supabase.com/docs/guides/api/securing-your-api, truy cập ngày 07/11/2026.